



Tema 11

Sisteme de securitate

dr. Arina ALEXEI

Obiectivele temei

- Determinarea amenințărilor și atacurilor posibile pentru o organizație anume
- Realizarea managementului activelor informaționale
- Studierea metodelor de management al riscului de securitate
- Studierea posibilelor controale de acces ce pot fi implementate și configurate
- Realizarea planului de răspuns la incidente

- Riscul este probabilitatea de pierdere din cauza unei amenințări – un act rău intenționat sau un eveniment neașteptat – care deteriorează sistemele informaționale sau activele organizaționale.
- Impactul riscului reprezintă daunele suferite de un eveniment care provoacă pierderea bunurilor sau întreruperea serviciului.
- Scopul managementului riscului este de a reduce aceste amenințări la un nivel acceptabil și de a implementa controale pentru a menține acest nivel.
- Nivelurile de amenințare pot fi clasificate astfel:
 - ✓ **Risc ridicat** - Neglijența înseamnă că nu sunt luate măsuri sau controale pentru a reduce riscul. Amenințarea este extrem de mare, iar costul unui incident poate fi catastrofal.
 - ✓ **Risc mediu** - Acordarea atenției cuvenite poate ajuta la scăderea nivelului de risc. Riscul încă există, dar acești pași rezonabili reduc o potențială pierdere.
 - ✓ **Risc acceptabil** - Exercițarea diligenței necesare implică luarea de măsuri rezonabile pentru a elimina riscul. Unele riscuri mai există, dar sunt implementate controale multiple pentru a preveni potențialele pierderi.

- Riscul poate fi intern, extern sau ambele. Impactul său se poate răspândi în întreaga organizație și poate afecta alte entități externe.
- Promovarea conștientizării riscurilor în cadrul organizației îi ajută pe angajați să dezvolte o înțelegere a riscurilor existente, a impactului lor potențial și a modului în care organizația poate gestiona aceste riscuri.



Managementul riscului de securitate

Procesul de management al riscului

- Managementul riscului este un proces formal care măsoară impactul unei amenințări și costul implementării controalelor sau contramăsurilor pentru atenuarea acelei amenințări.
- Riscul nu poate fi eliminat complet, dar poate fi gestionat la un nivel acceptabil.
- Toate organizațiile acceptă un anumit risc, iar costul unei contramăsuri nu ar trebui să fie mai mare decât valoarea activului protejat.
- Etapele procesului de management al riscului includ:
 - ✓ *Încadrarea riscului*
 - ✓ *Evaluarea riscului*
 - ✓ *Răspuns la Risc*
 - ✓ *Monitorizare risc*

Managementul riscului de securitate

Procesul de management al riscului

Termen	Descriere
Încadrarea riscului	Identificați amenințările din întreaga organizație care cresc riscul. Amenințările identificate includ pierderea sau deteriorarea proceselor și produselor, atacuri, potențiale eșec sau întrerupere a serviciilor, vătămarea reputației organizației, răspunderea juridică și pierderea proprietății intelectuale.
Evaluarea riscului	Odată ce un risc a fost identificat, acesta este evaluat și analizat pentru a determina gravitatea pe care o reprezintă amenințarea. Unele amenințări pot bloca întreaga organizație, în timp ce alte amenințări sunt doar inconveniente minore. Riscul poate fi prioritizat după impactul financiar real (analiza cantitativă) sau un impact la scară asupra funcționării organizației (analiza calitativă).
Răspuns la risc	Elaborați un plan de acțiune pentru a reduce expunerea generală la riscul organizației. Managementul ierarhizează și prioritizează amenințările; o echipă determină apoi cum să răspundă fiecărei amenințări. Riscul poate fi eliminat, atenuat, transferat sau acceptat .
Monitorizare risc	Examinați continuu reducerile de risc datorate acțiunilor de eliminare, atenuare și transfer. Nu toate riscurile pot fi eliminate, așa că amenințările care sunt acceptate trebuie monitorizate îndeaproape. O organizație poate folosi un registru de riscuri – un program software sau un serviciu cloud – pentru a înregistra informații despre riscurile identificate. Registrul de risc conține detalii despre risc și controalele implementate sau strategiile de răspuns utilizate.

Managementul riscului de securitate

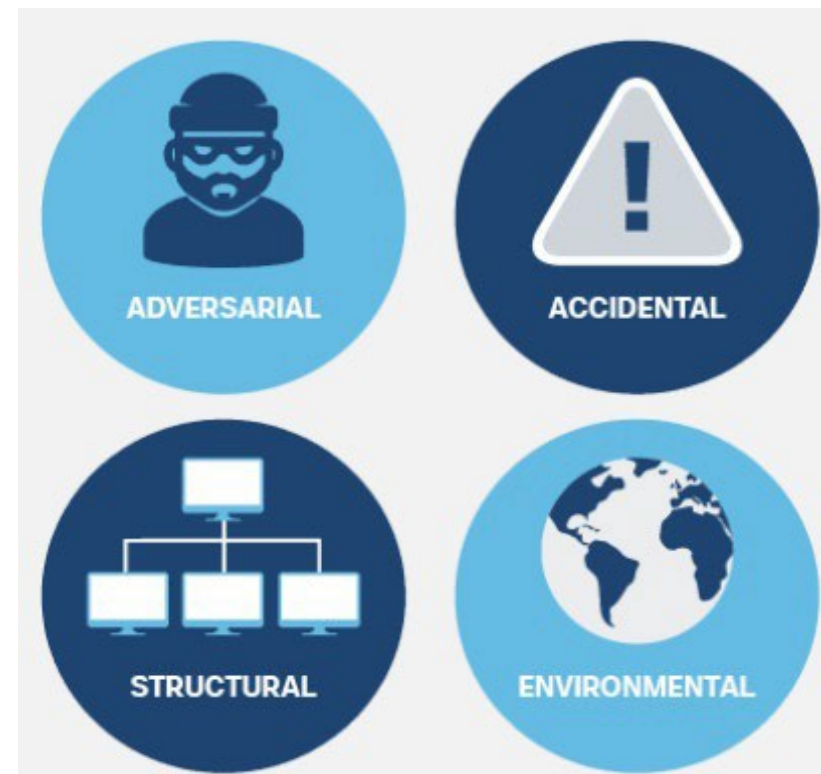
Exemplu registrul riscurilor cibernetice

REGISTRUL RISCURILOR DE SECURITATE										
Departament/Direcție:				Responsabil ER:			Aprobat de:			No de referință
Proces academic:				Membru ER 1:						
Locația PA:				Membru ER 2:			Semnătura			
Data:				Membru ER 3:			Nume:			
Versiunea:				Membru ER 4:			Funcție:			
Revizuire planificată:				Membru ER 5:			Data:			
Identificarea amenințărilor/vulnerabilităților				Evaluarea riscului			Controlul riscului			
Categorie active	Active de suport	Amenințări/ Vulnerabilități	Risc ID	Impact	Probabilitatea	Valoarea riscului	Opțiuni tratare riscuri	Controale implementate	Proprietarul activului	Comentarii
Echipamente terminale										
Software										
Rețea și comunicații										
Personal										
Infrastructură										

Evaluarea riscului de securitate

Tipuri de surse de amenințări

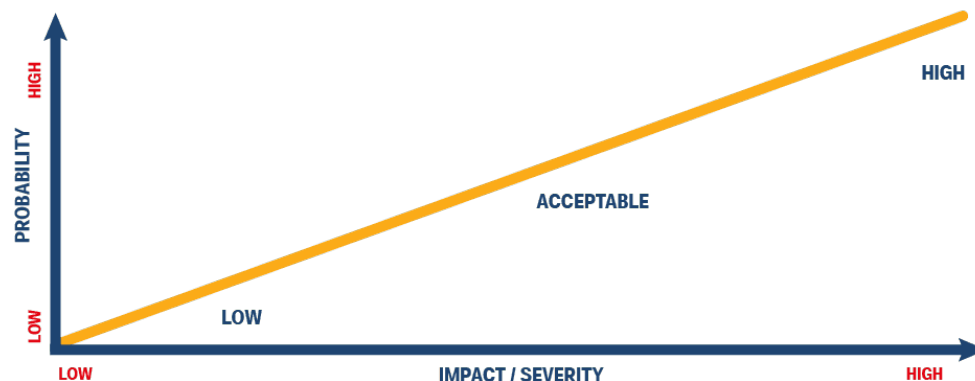
- O amenințare este potențialul ca o vulnerabilitate să fie identificată și exploatată, în timp ce un vector de amenințare este calea pe care un atacator o folosește pentru a afecta ținta.
- Tipurile de surse de amenințări sunt clasificate după cum urmează și pot fi interne sau externe:
 - ✓ Adversari: amenințări din partea unor persoane, grupuri, organizații sau națiuni.
 - ✓ Accidentale: acțiuni care au loc fără o intenție rău intenționată.
 - ✓ Structurale: defecțiuni ale echipamentelor și software-ului.
 - ✓ De Mediu: dezastrele externe care pot fi fie naturale, fie cauzate de oameni, cum ar fi incendiile și inundațiile.



Evaluarea riscului de securitate

Metodologia de evaluare a riscurilor

- Organizațiile își evaluează și își examinează riscurile operaționale efectuând o evaluare a riscurilor pentru a se asigura că gestionarea riscurilor își îndeplinește toate obiectivele de afaceri.
- Încercarea de a determina probabilitatea unui atac din partea unei surse de amenințare umană poate fi dificilă și poate implica evaluarea nivelului de calificare, motivului, oportunității și dimensiunii.
- La evaluarea vulnerabilității, factori precum ușurința de descoperire, exploatarea, conștientizarea și detectarea intruziunilor joacă un rol.
- Utilizați o combinație de estimare și date istorice pentru a oferi cea mai precisă probabilitate de apariție a unui eveniment.
- În cele din urmă, determinați amploarea impactului. O măsură simplă a impactului poate varia de la foarte scăzut la extrem de mare sau de la un impact nesemnificativ la un impact catastrofal.



- Analiza riscurilor examinează pericolele prezentate de evenimente naturale și cauzate de oameni pentru activele unei organizații.
- Un utilizator realizează o identificare a bunurilor pentru a ajuta la determinarea activelor de protejat.
- O analiză de risc are patru obiective:
 1. **Identificați activele și valoarea acestora.**
 2. **Identificați vulnerabilitățile și amenințările.**
 3. **Cuantificați probabilitatea și impactul amenințărilor identificate.**
 4. **Echilibrează impactul amenințării cu costul contramăsurii.**
- Două abordări ale analizei riscului sunt:
 5. **Analiza cantitativă a riscului**
 6. **Analiza calitativă a riscului**

Clasificarea activelor atribuie resursele unei organizații în grupuri pe baza caracteristicilor comune.

Cele mai critice informații trebuie să primească cel mai înalt nivel de protecție și pot chiar necesita o manipulare specială.

Un sistem de etichetare poate fi utilizat pentru a determina cât de valoroase, cât de sensibile și cât de critice sunt informațiile.

Pașii pentru identificarea și clasificarea activelor sunt:

Pasul 1: Determinați categoria adecvată de identificare a activelor:

- **Date**
- **Software**
- **Hardware**
- **Rețea și comunicații**

În facultate este raportat un posibil incident de securitate. Un profesor observă accesări suspecte în contul ELSE, mai mulți studenți reclamă probleme la Wi-Fi și apariția unei rețele cu denumire asemănătoare celei oficiale.

Într-un laborator IT, câteva calculatoare funcționează lent și au sesiuni deschise în browser. În aceeași zi, un fișier cu date despre studenți este transmis greșit unui grup mai larg, iar mai mulți utilizatori primesc un email care solicită „verificarea urgentă a contului”.

Fiecare grupă analizează un anumit domeniu, conform tabelului:

Grupa	Domeniu de risc
TI-241	Identitate și control acces
TI-242	Rețea și Wi-Fi
TI-243	Laboratoare IT
TI-244	Dispozitive personale ale studenților
TI-245	Platforme educaționale
SI-241	Date academice și personale
SI-242	Factor uman și proceduri

SARCINA 1

Pe baza domeniului atribuit grupei voastre, identificați **minimum 6 active concrete din facultate** și clasificați-le în:

- **Date**
- **Software**
- **Hardware**
- **Rețea**

Tip activ	Activ concret
Date	
Software	
Echipamente	
Rețea	

Nu folosiți termeni generici („server”, „date”), ci exemple reale (ex: „cont ELSE student”, „PC laborator 3-xxx”).



Timp: 5–7 minute, individual, pe foaie.

Sarcina 2 – Identificarea vulnerabilităților

- Pentru fiecare activ identificat la Sarcina 1, notați **minimum o vulnerabilitate reală** care ar putea permite compromiterea aceluia activ.
- pentru fiecare, adăugați unde exact apare în facultate (1 rând)

Activ	Vulnerabilitate	Loc unde apare

Timp: 5–7 minute, individual, pe foaie.

Sarcina 3 – Identificarea amenințărilor

Pentru fiecare activ și vulnerabilitate identificate anterior, notați **o amenințare** care poate exploata acea vulnerabilitate.

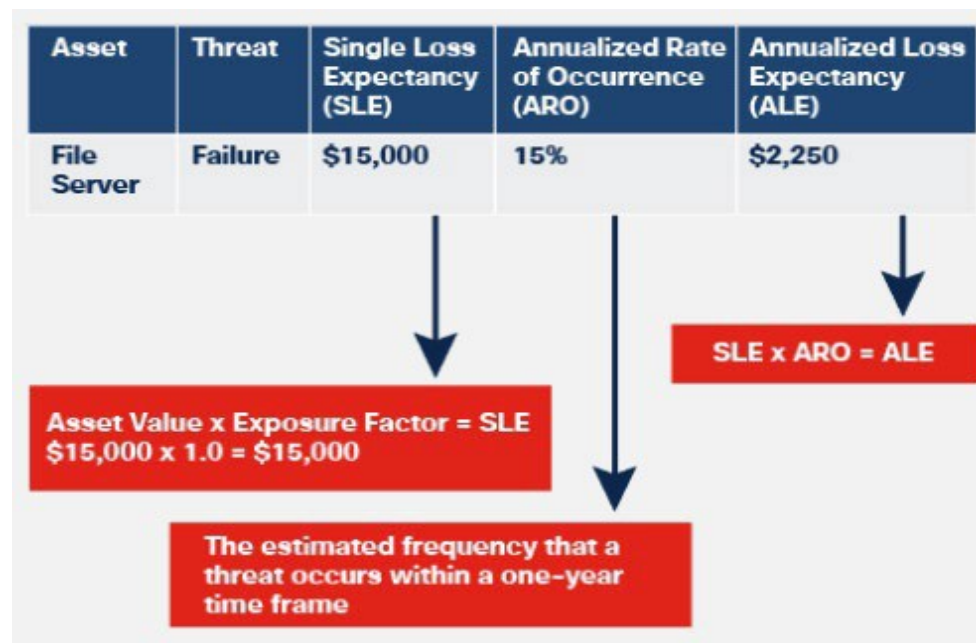
Activ	Vulnerabilitate	Amenințare

Timp: 5–7 minute, individual, pe foaie.

Evaluarea riscului de securitate

Analiza cantitativă a riscurilor

- O analiză cantitativă a riscului atribuie numere procesului de analiză a riscului.
- În acest exemplu, valoarea activului este costul de înlocuire a serverului de fișiere (activul).
- **Valoarea unui activ** poate fi măsurată și prin venitul obținut folosind activul.
- **Factorul de expunere (EF)** este o valoare subiectiv exprimată ca procent din serverul de fișiere pierdut din cauza unei anumite amenințări. Dacă are loc pierdere totală, E este egal cu 1,0 (100%).
- **Rata anualizată de apariție (ARO)** este probabilitatea ca pierdere să apară în cursul anului. Un ARO poate fi mai mare de 100% dacă o pierdere poate apărea mai mult de o dată pe an.
- **Calculul așteptării anuale a pierderii (ALE)** oferă conducerii câteva îndrumări cu privire la ce ar trebui să cheltuiască o organizație pentru a proteja serverul de fișiere.



Sarcina 1 – Calcul de bază

Un PC de laborator are valoarea de **1200€**. În cazul unui incident (malware), se pierde aproximativ **40% din valoare**. Probabilitatea anuală este de **25%**.

Calculați:

- 1.SLE
- 2.ARO
- 3.ALE

Antivirus pe PC laborator: **20–40€ / an / PC**
Se merită de implementat?

Sarcina 2 – Alegere decizie (importantă)

Aveți următorul risc:

- Activ: cont ELSE profesor
- Valoare estimată: **1000€**
- EF = **0.6**
- ARO = **0.2**

Un control de securitate (MFA) costă **300€/an**

Calculați:

1.SLE

2.ALE

Decideți:

Se implementează controlul sau nu?

Evaluarea riscului de securitate

Analiza calitativă a riscurilor

Analiza calitativă a riscurilor folosește opinii și scenarii care calculează probabilitatea unei amenințări în raport cu impactul acesteia.

De exemplu, o defecțiune a serverului poate fi probabilă, dar impactul său poate fi doar marginal. O matrice de risc este un instrument care ajută la prioritizarea riscurilor pentru a determina pentru care organizația trebuie să dezvolte un răspuns.

Rezultatele pot fi clasificate și utilizate ca ghid pentru a determina dacă organizația întreprinde vreo acțiune.

Când matricea de risc este codificată cu culori, așa cum se arată aici, se face referire la o hartă termică a riscurilor.

Category	Frequent - 5	Likely - 4	Occasional - 3	Seldom - 2	Unlikely - 1
Catastrophic - 4	20	16	12	8	4
Critical - 3	15	12	9	6	3
Marginal - 2	10	8*	6	4	2
Negligible - 1	5	4	3	2	1

* Server Failure

Evaluarea riscului de securitate

Analiza calitativă a riscurilor

Valoare calitativă	Valoare numerică	Impact (facultate)
Neglijabil	1	Fără impact semnificativ; nu afectează procesul educațional; fără pierderi de date sau reputație
Redus	2	Impact minor; afectare temporară a unui serviciu (ex: acces limitat la ELSE); pierderi minore de date
Mediu	3	Impact moderat; indisponibilitate parțială a platformelor (ELSE, email); afectare a unor date sau activități academice
Sporit	4	Impact major; modificare note, pierdere date importante, indisponibilitate servicii critice; afectare reputație facultate

Valoare calitativă	Valoare numerică	Probabilitate
Neglijabilă	1	Incident rar (o dată la câțiva ani)
Redusă	2	Incident ocazional (o dată pe an)
Medie	3	Incident frecvent (de câteva ori pe an / lunar)
Sporită	4	Incident foarte frecvent (săptămânal sau continuu)

$$R = \text{Probabilitate} \times \text{Impact}$$

Impact \ Probabilitate	1	2	3	4
1 (Neglijabil)	 1	 2	 3	 4
2 (Redus)	 2	 4	 6	 8
3 (Mediu)	 3	 6	 9	 12
4 (Sporit)	 4	 8	 12	 16

SARCINA 4 – Analiza riscurilor

Pentru două active diferite:

- **realizați o analiză calitativă pentru primul activ (justificați valoarea probabilității și a impactului)**
- **realizați o analiză cantitativă pentru al doilea activ**

- Atenuarea implică reducerea probabilității sau severității unei pierderi din cauza amenințărilor.
- Multe controale tehnice atenuează riscul, inclusiv sistemele de autentificare, permisiunile pentru fișiere și firewall-urile.
- Organizațiile trebuie să înțeleagă că atenuarea riscurilor poate avea atât efecte pozitive, cât și negative asupra organizației.
- O bună atenuare a riscurilor găsește un echilibru între impactul negativ al contramăsurilor și controalelor și beneficiul reducerii riscului.

Cele mai comune modalități de atenuare a riscului sunt:

Termeni	Descriere
Acceptați riscul și reevaluați periodic	O strategie pe termen scurt este de a accepta riscul care necesită crearea unor planuri de urgență pentru acel risc. Oamenii și organizațiile trebuie să accepte riscul zilnic.
Reduceți riscul prin implementarea controalelor	Metodologiile moderne reduc riscul prin dezvoltarea progresivă a software-ului și prin furnizarea de actualizări și corecții regulate pentru a aborda vulnerabilitățile și configurațiile greșite.
Evitați riscul schimbând total abordarea	Un plan bun de diminuare a riscurilor poate include două sau mai multe strategii.
Transferați riscul unei terțe părți	Serviciile de externalizare, achiziționarea de asigurări și achiziționarea de contracte de întreținere sunt toate exemple de transfer de risc. Angajarea de specialiști care să îndeplinească sarcini critice pentru a reduce riscul poate fi o decizie bună și poate aduce rezultate mai mari cu investiții pe termen lung mai puține.

Controale de securitate

Tipuri de controale de securitate

- Riscul inherent al unui sistem este riscul pe care sistemul îl prezintă în mod inherent - fără control de persoane, proces sau tehnologie.
- Controalele de securitate sunt măsuri de protecție sau contramăsuri pe care o organizație le implementează pentru a evita, detecta, contracara sau minimiza riscurile de securitate pentru activele organizației.

Cele trei tipuri de control sunt:

- **Controale administrative** - constau în proceduri și politici pe care o organizație le pune în aplicare atunci când se ocupă de informații sensibile. Aceste controale determină modul în care oamenii acționează.
- **Controale tehnice** - implică hardware și/sau software implementat pentru a gestiona riscul și a oferi protecție.
- **Controale fizice** - mecanisme precum garduri și încuietori instalate pentru a proteja sistemele, facilitățile, personalul și resursele. Controalele fizice separă fizic oamenii sau alte amenințări de sisteme.

Controale de securitate

Controale funcționale de securitate

Utilizarea funcțională a unei anumite măsuri de protecție sau contramăsuri va ajuta la determinarea motivului pentru alegerea și implementarea acesteia.

Termeni	Descriere
Controale preventive	Controalele de securitate preventive opresc activitățile nedorite și neautorizate și/sau aplică restricții pentru utilizatorii autorizați.
Controale cu efect de descurajare	Un element de descurajare are ca scop descurajarea de a se întâmpla ceva.
Controale detective	Detectarea controlului accesului identifică mai multe tipuri de activitate neautorizată. Ele nu sunt o măsură preventivă și se concentrează în schimb pe descoperirea unei breșe de securitate după ce aceasta a avut loc.
Controale corective	Ele contracarează ceva nedorit prin restabilirea sistemului la o stare de confidențialitate, integritate și disponibilitate. De asemenea, pot restabili sistemele la normal după ce apare o activitate neautorizată.
Controale de recuperare	Controalele de securitate de recuperare restaurează resursele, funcțiile și capacitățile la o stare normală după o încălcare a unei politici de securitate.
Controale cuprinzătoare	Ele oferă opțiuni pentru alte controale pentru a consolida aplicarea în sprijinul unei politici de securitate. Un control compensator poate fi, de asemenea, o înlocuire utilizată în locul unui

SARCINA 5: Implementarea controalelor de Securitate

Pentru unul dintre riscurile identificate anterior, propuneți controale de securitate adecvate. Completați tabelul:

Tip control	Preventiv	Detectiv	Corectiv
Fizic			
Tehnic			
Administrativ			

Instrucțiuni pentru studenți:

- Alegeți un singur risc (din analiza anterioară)
- Propuneți minim 1 control pentru fiecare categorie
- Controalele trebuie să fie: concrete (nu generale), aplicabile în facultate (nu „firewall”, ci „regulă firewall pentru...”)
- Legat direct de vulnerabilitate pentru fiecare control, specificați ce vulnerabilitate reduce (1 rând))

Timp 10–15 minute, individual

SARCINA FINALĂ – Prioritizare risc

Alegeți **cel mai critic risc** din analiza voastră conform incidentului inițial și răspundeți:

1. De ce este cel mai periculos?
2. Ce s-ar întâmpla dacă NU implementați controale?
3. Ce control implementați primul și de ce?

 5 min

Standarde de securitate

Suita standardelor de securitate 27000

Standardele ISO 27000 descriu implementarea unui sistem cuprinzător de management al securității informațiilor (ISMS). Un ISMS constă din toate controalele administrative, tehnice și operaționale pentru a păstra informațiile în siguranță în cadrul unei organizații.

Controalele de referință se regăsesc în standardul ISO 27001, Anexa A și includ:

- Controale organizaționale,
- Controale pentru resursele umane,
- Controale fizice,
- Controale tehnologice

!!! De analizat conținutul standardului ISO 27001 atașat la lucrul individual.

Pentru managementul riscului ISO a elaborat standardul ISO 27005 care include specificații pentru:

- Managementul riscului,
- Liste orientative cu amenințări de securitate tipice
- Liste cu vulnerabilități de securitate
- Abordări pentru evaluarea riscului de securitate

!!! De analizat conținutul standardului ISO 27005 atașat la lucrul individual.

Concluzii la temă

- Pentru implementarea unui sistem de securitate este necesar de a parcurge anumiți pași obligatorii;
- Realizarea procesului de management al activelor informaționale este primul pas, care permite administratorilor să determine, clasifice și standardizeze activele informaționale importante;
- Ca proces important în managementul activelor este identificarea vulnerabilităților și amenințărilor specifice pentru activele informaționale ale companiei;
- Realizarea procesului de management al riscului de securitate este proces mandatoriu, poate fi realizată atât evaluarea cantitativă, cât și evaluarea calitativă a acestuia;
- Suita de standarde ISO 27000 poate fi utilizată în procesul de implementare a sistemelor de securitate.

Bibliografie

1. Mihai Chiru. Criptografia - Concepte, tehnici și aplicații.
2. William Stallings . "Criptografie și securitate informatică"
3. Behrouz A. Forouzan și Debdeep Mukhopadhyay. "Criptografie și rețele de calculatoare"
4. Niels Ferguson, Bruce Schneier și Tadayoshi Kohno. "Cryptography Engineering: Design Principles and Practical Applications"
5. Alfred J. Menezes, Paul C. van Oorschot și Scott A. Vanstone. "Handbook of Applied Cryptography"
6. Jonathan Katz și Yehuda Lindell. "Introduction to Modern Cryptography".